Systems Administration ASIST

Topic 5

Security and services

Security and services

- Networks are a means which must be protected from attacks
- They are sometimes very extensive, making it difficult to ensure that there is no improper physical access.
- They are usually linked to external access, either for Internet access or to provide remote access for authorized users, so in these cases there is always a common point for the internal network (intranet) and an external network (Internet)
- This common point delimits the perimeter of the internal network and where its defense is usually located
- In this case it is called **perimeter defense**
- The current situation, with the increase in wireless networks, the need to protect the infrastructure from attacks by social engineering to valid users or even in order to mitigate malicious intentional actions, has led to the need to widen the *perimeter* and the adoption of **defense in depth**

Security and services

- It is important to change pre-established ideas and evolve from **perimeter defense** to **defense in depth**

- Defense in depth is a concept that applies several layers of protection
  - The idea is that if one of them fails, there are still others that ensure the defense
- With this principle we agree that encrypting and authenticating sensitive information stored in the infrastructure is an idea to consider
- Of course there is a processing cost… which according to BCM must be weighed against the benefit obtained

Security and services

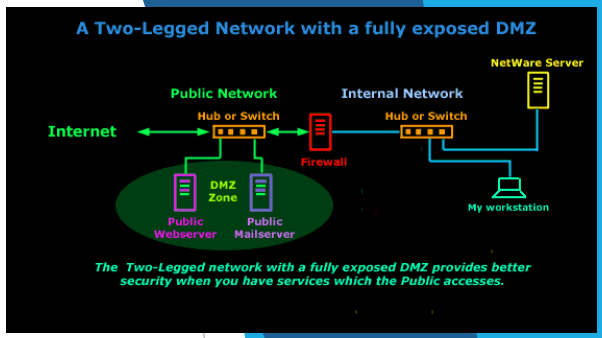
- A network infrastructure is usually divided into three zones:
  - The datacenter network, where external access servers are located and the base of the network infrastructure
  - The internal network, where exclusively internal servers are located, the workstations and assets that guarantee their functioning and interconnection both to internal and external servers, if applicable
  - External networks and the devices that ensure access to them
- To delimit these networks or at least some of these networks are active that prevent or mitigate improper actions, called *firewalls*
- Public access servers can be the most problematic
  - On the one hand, they need to ensure public access to the desired services
  - On the other hand, they can act as access points to attackers
- It is therefore common to place public access servers in a semi-isolated network from the internal network, which is called the ***Demilitarized Zone*** (**DMZ**)

Security and services

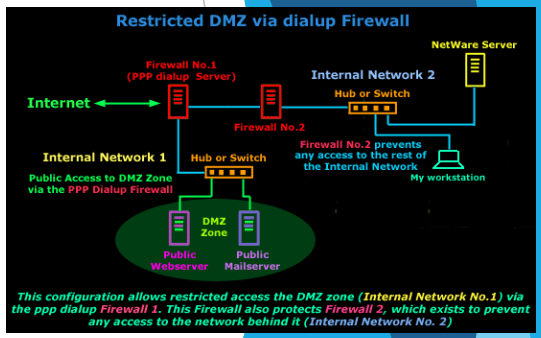
- The use of segmentation of networks by VLAN does not offer security guarantees because this segmentation is logical
  - Therefore, regardless of whether this segmentation is carried out, it should always be considered as a means of shared transmission
- Firewalls are usually installed on routers because they are the border points between networks, both internal (Intranet and/or datacenter) and external (Internet)
  - Even because routers have the possibility to define ACL's and are the devices that forward packets through the routing table
- There are dedicated firewalls (appliance) but it is also an application that can be installed or configured on a router or even a host

Security and services

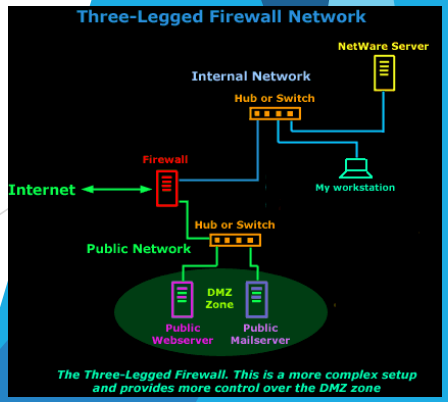
- The segmentation of a sensitive network must always be protected by a firewall
- There are several ways to implement the firewall according to the need and objective
- The topology represents the number of networks it connects to
- In the situation shown in the figure above (*twolegged*), the internal network is protected by the firewall but with a DMZ totally exposed and unprotected
- In the middle figure (two firewall *twolegged*), the DMZ is now protected using two firewalls
- But in the figure below (*threelegged*) the same functionality is achieved although using only one firewall



Source: Firewall.cx



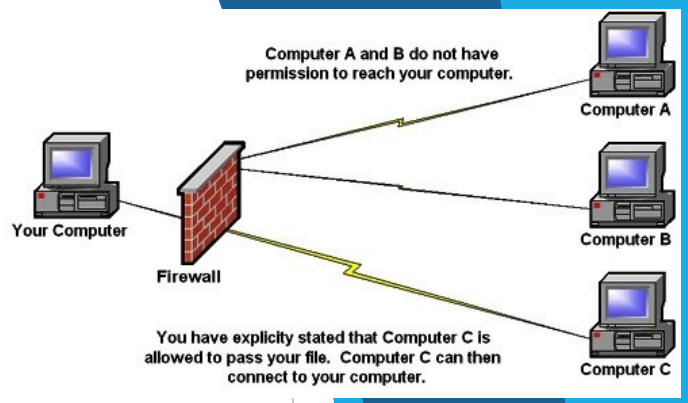
Source: Firewall.cx



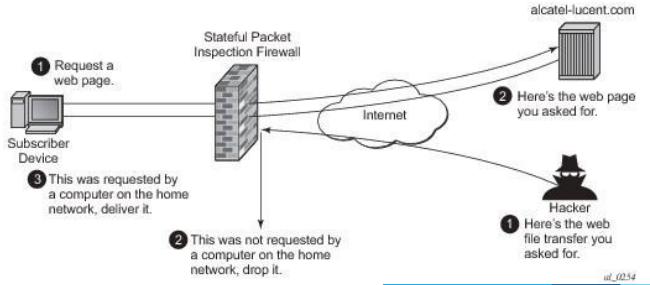
Source: Firewall.cx

Security and services

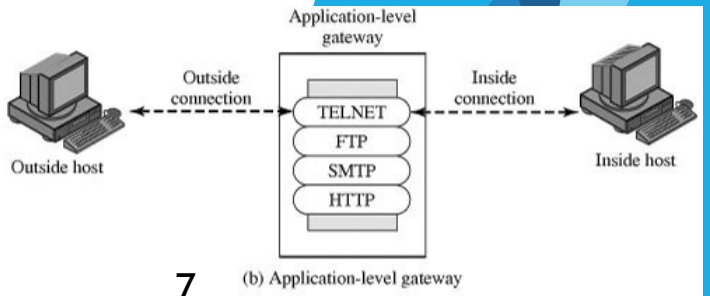
- The type represents the form of action, as
- *Packet-Filter* or *static firewall* or *screening router*
  - Apply a set of static rules to each IP packet that traverses it
  - It is based only on the IP header (level 3 of the OSI model)
- *Stateful Packet Inspection*
  - In addition to static rules, it applies temporary dynamic rules, based on the configuration and recent communication past.
- *Application-Level* or *Proxy Server* or *Bastion Host*
  - Relays IP packets according to the type of traffic allowed



Source: Quizlet



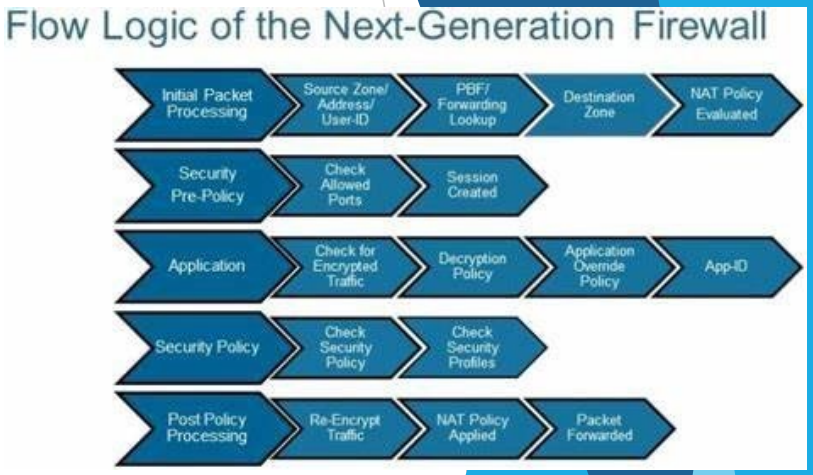
Source: Alcatel-Lucent



Source: Alcatel-Lucent

Security and services

- ***Next Generation Firewall*** (**NGFW**)
  - More recent, incorporate the features of Packet Filter and Stateful, plus application control, ***Intrusion Prevention System*** (**IPS**) and an environment (*sandbox*) where suspicious content can be inspected



Source: Palo Alto

Security and services

- The firewall is a useful helper in the defense of a network, however some considerations must be taken into account
  - Does not protect attacks encapsulated in allowed traffic
  - It does not protect internal attacks because it only analyzes and acts against the traffic that passes through it
  - Does not protect against viruses installed in downloaded programs
  - It is often configured to allow all traffic from the internal network and acts only on traffic from the external network
    - And in those cases if it is not allowed because it is a response to a previous request from the internal network
  - That is, it assumes that all the *bad guys* are on the outside and everyone on the inside are *good guys*
- If an internal user is tricked and executes malicious code, that code can inhibit the firewall

Security and services

- If there are configuration errors or difficulties in recognizing new applications, it can make legitimate access difficult or impossible
- The encapsulation of one type of traffic in another (for example, ftp encapsulated in http) may call into question the rules defined by the system administrator
- Finally, keep in mind that the firewall will be a burden on processing

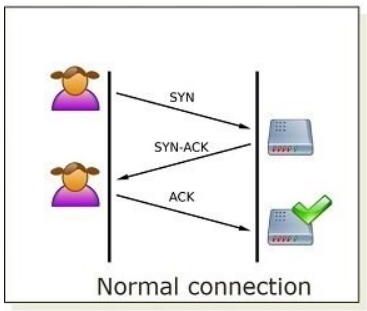
Security and services

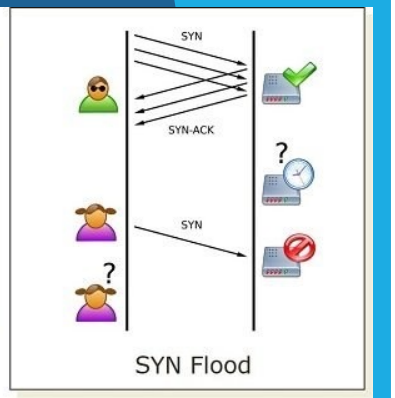
- Taking into account the advantages and weaknesses of the firewall, its use is recommended
- But its type and rules must be adjusted to the zone it protects
  - In a DMZ, **allow only responses to valid requests** and **do not initiate requests** except in absolutely necessary and controlled situations
  - Permissions must be limited to the minimum essential for each service
    - It makes no sense (and could be exploited by attackers) to allow SMTP traffic to a server that is dedicated exclusively to HTTP for example

Security and services

- From the internal side of the firewall, that is, on the local network, a user can, through malice or chance, enhance a set of actions that violate the security of internal communication
- Among the possible actions we highlight the traffic inspection (*sniffing*), the use of invalid IP addresses (*spoofing*) and the interposition attacks (*Man-in-the-Middle MITM)*
  - Through sniffing, all traffic from level 2 to the level of ongoing communication of the OSI model is inspected
  - Through spoofing, actions such as tricking other systems (MAC spoofing, ARP spoofing, IP spoofing) can be triggered, leading them to address packets sent to systems that are infected
  - Normally resorting to spoofing in advance, an attacker could lead systems to resort to an invalid or infected DNS server

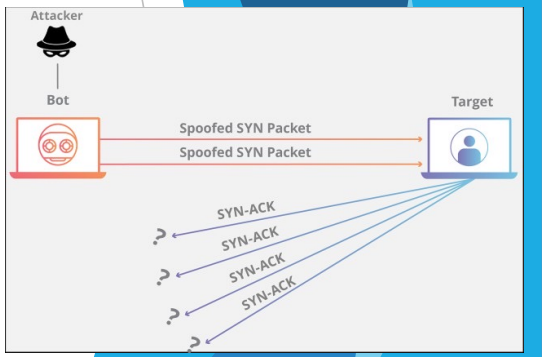
Security and services





Source: Firewall.cx

- On the external side, take into account *Denial of Service* (**DoS**) and *Distributed Denial of Service* (**DDoS**) attacks
- These are attacks that execute legitimate requests to public access systems, but taking advantage of the way protocols work, they try to exhaust the resources of internal systems.
  - A static firewall cannot prevent these attacks
- The difference between a **DoS** and a **DDoS** is that the first comes from a single system (although tools allow it to simulate others, called decoys or zombies) while the second is a concerted action by multiple systems
  - It is estimated that in 2022 there will be 14.5 million DDoS attacks (source: Cybercrime magazine)
- A **DoS** or **DDoS** attack taking advantage of **SYN Flood** is shown in the images



Source: PureVPN

Security and services

- On the external side, allow only and only access traffic to the internal network that can be started externally
  - But ensuring that responses to legitimate requests are ensured
- It is the responsibility of the system administrator to mitigate or inhibit spoofing
  - Internal, which tries to leave the internal network with an invalid source address on that network
  - External, which tries to enter the internal network with an internal network source address
    - It is unreasonable for traffic from an external source but with an internal network IP address to pass through the firewall
    - Attackers can try this method because the rule is usually *who is from the inside is trustworthy*

Security and services

- Network assets are central and crucial points in the functioning of the infrastructure
- By default, they operate in *best-effort* mode, that is, all traffic is treated in the same way and the exit order is *first-in-first-out* (FIFO)
- In pressure situations this implies that some traffic can be discarded - when the asset's storage capacity is exhausted - or delayed - while waiting for its turn to be processed
- However, there may be traffic considered a priority, the objective being to be processed in a privileged way
- So what are the delays that can occur in the infrastructure?

Security and services

- Infrastructure delays (*latency*) and statistical variations (*jitter*) of these delays, in addition to the losses due to depletion of the capacity of the assets already described, lead to the lack of a guarantee of continued traffic delivery
- The delay that a packet experiences from being sent to being received at the final node is the sum of four delays[1]
  - **Processing delay** where the correction and processing of the header occurs
  - **Waiting delay** in assets between the sending and receiving nodes
  - **Transmission delay** that depends on the speed of the channels crossed between the sending and receiving nodes
  - **Propagation delay** that depends on the distance between nodes

[1] Adapted from Prof. Legatheaux Martins

Security and services

- The processing delay can be considered constant
- The waiting delay it is a function of the total traffic that the asset has to process, and is therefore random; however can be estimated by

$$\boldsymbol{Waiting\ delay} = \frac{\boldsymbol{Packet\ medium\ size\ (bits) x\ Average\ arrival\ rate}}{\boldsymbol{Transmission\ speed\ (bps)}}$$

- The transmission delay is a function of the speed of each segment traversed

$$\boldsymbol{Transmission\ delay} = \frac{\boldsymbol{Packet\ size\ (bits)}}{\boldsymbol{Transmission\ speed\ (bps)}}$$

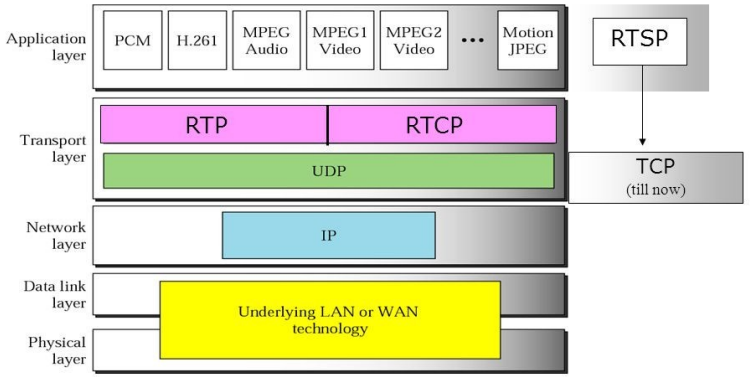
- The propagation delay depends on channel bandwidth

$$\boldsymbol{Propagation\ delay} = \frac{\boldsymbol{Distance\ (Km)}}{\boldsymbol{Propagation\ speed\ (Km/s)}}$$

Security and services

- All of these issues drive pressure on infrastructure performance
- Differentiating traffic and/or adopting mechanisms to optimize performance is sometimes necessary
- Among the possible protocols, ***Real Time Transport Protocol*** (**RTP**) stands out
  - RFC 3550 in its most recent definition
  - Oriented to transport traffic in real time, such as video, audio, etc.
  - Does not handle errors or flow control
  - Operates in conjunction with the ***Real Time Control Protocol*** (**RTCP**) that controls the service and checks its quality
- While RTP operates over UDP, the ***Real Time Streaming Protocol*** (**RTSP**), RFC 2326, operates over TCP and allows the control of streaming, making it possible to pause, fast forward, rewind, etc.

Protocol stack for multimedia services



Source: PBXDom

Security and services

- But the pressure is not always on interactive traffic, and there is a propagation delay along the traversed route, as already seen
- And this can be improved, if possible by reducing the size of the packets and/or by changing the processing of the packets on the intermediate devices, privileging the traffic considered a priority
- Any traffic contains an **overhead** caused by encapsulation over the TCP model

$$overhead = \frac{Total\ information\ transmitted\ - Useful\ information}{Total\ information\ transmitted}$$

- Which in turn impairs **efficiency**

$$Efficiency = \frac{Useful\ information}{Total\ information\ transmitted}$$

Security and services

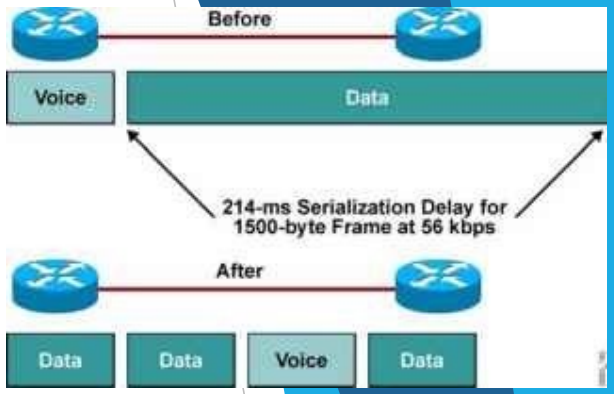
Protocol headers	Total header size (bytes)	Min. compressed header size (bytes)	Compression gain (%)
IP4/TCP	40	4	90
IP4/UDP	28	1	96.4
IP4/UDP/RTP	40	1	97.5
IP6/TCP	60	4	93.3
IP6/UDP	48	3	93.75
IP6/UDP/RTP	60	3	95

Source: EFFNET AB

- IP, RTP and TCP headers sometimes represent a significant weight in efficiency and overhead
- Some header compression mechanisms have been developed allowing for a reasonable improvement
- Stand out among these
  - **CTCP** (RFC 1144) – compression of IPv4 and TCP headers
  - **IPHC** (RFC 2507) – compression of IPv4, IPv6, UDP, TCP and RTP headers
  - **CRTP** (RFC 2508) – compression of IPv4, IPv6, UDP and RTP headers
  - **ROHC** (RFC 3095) – compression of IPv4, IPv6, ESP (that we'll cover later) headers
- The application of these mechanisms is more appropriate in low-speed connections, and can be applied between the ends of the connection or between intermediate nodes, transparently to the final nodes

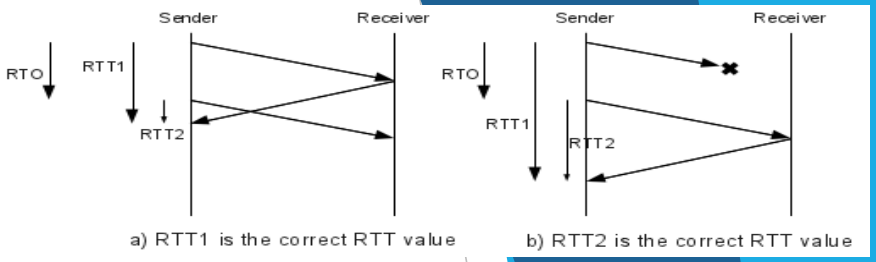
Security and services

- If the FIFO system is maintained at the nodes that delimit the low-speed connection, the possibility that the intended traffic will wait for another large traffic to cross the channel causes a delay that may not be reasonable
- ***Link Fragmentation and Interleaving*** (**LFI**) segments large packets, thus allowing less delay to priority packets
- This technique can be applied in intermediate nodes transparently to the final nodes



Source: Cisco

Security and services



Source: Everything about nothing

- Another possible technique to reduce delays is to control TCP congestion
- This protocol works as we know in **stop & wait** mode or in a **sliding window**
- In **stop & wait** mode the sender sends a packet and waits for acknowledgment of receipt (**ACK**) by the receiver, waiting for a maximum time called ***Retransmission TimeOut*** (**RTO**)
- In **sliding window** mode the window size is defined by the receiver although it is adjusted during communication
- According to the distance between the nodes and the occupation of the intermediate channels, the **RTO** is also adjusted, measuring the delay times between the emission and the reception of the **ACK** – the ***Round Trip Time*** (**RTT**)
- After some (few) transmissions the transmitter calculates the initial **RTO** as

$$RTO = 3\ x\ RTT$$

Security and services

- The sliding window can cause congestion in the channel, as delays in confirming receipt will lead to the reshipping of packets considered lost, so an additional flow control mechanism has been defined.
- RFC 5681 defines four interconnected TCP congestion control algorithms to control TCP congestion
- The start of transmission on a channel with unknown conditions requires TCP to identify its capabilities, thus avoiding congestion.
- Likewise, after detecting congestion, it is necessary to identify whether the propagation conditions have changed
- To do this, some parameters are defined
  - ***Congestion window*** (**cwnd**) and ***Receiver window*** (**rwnd**)
  - ***Initial Window*** (**IW**)
  - ***Sender Maximum Segment Size*** (**SMSS**)
  - ***Slow start threshold (ssthresh)*** used to determine whether the **slow start** or congestion prevention algorithm is used to control transmission

Security and services

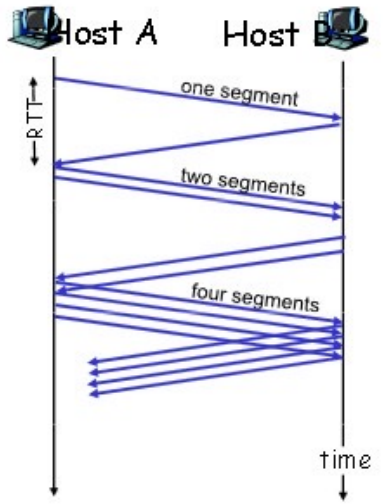
- In this mode, the initial indication of the maximum window size is announced by the receiver during the establishment of the connection (16 bits field in the TCP header)
- **cwnd** represents the limit of pending data that the sender can transmit before receiving an **ACK**
- **rwnd** represents the limit of pending data that the receiver can receive
- The minimum of these two values, **cwnd** and **rwnd**, define the window size
- The initial value of **IW** and **cwnd** is defined as
  - If **SMSS > 2190** bytes **IW = 2 x SMSS** and less or equal to 2 segments
  - If **1095 bytes < SMSS <= 2190** bytes **IW = 3 x SMSS** and less or equal to 3 segments
  - If **SMSS <= 1095** bytes **IW = 4 x SMSS** and less or equal to 4 segments

Security and services

- The initial value of **ssthresh** is arbitrarily high, but must be reduced to avoid traffic congestion
  - It is intended that it is the network conditions that define the window boundary and not the characteristics of the sender or receiver
- If **cwnd < ssthresh** the network is in **slow start** mode
- But if **cwnd> ssthresh** the congestion control kicks in
- In **slow start** mode **cwnd** value is increased up to the maximum of **SMSS** for each **ACK** received
- When **cwnd > ssthresh** or congestion is detected the transmission exits **slow start** mode
- In the congestion control mode **cwnd** is incremented by 1 segment per **RTT**

Security and services

- The **slow start** mode translates into practice by checking the bandwidth of the communication channel that can be applied in the communication
  - The adjustment of **cwnd** is exponential
- If data loss occurs **ssthresh** is adjusted to **50%** of the **cwnd** prior the loss
  - Which in turn will imply a smaller window size, penalizing communication
- To try to avoid penalties, RFC 5681 also defines **Fast Retransmit / Fast Recovery**
- The receiver must send a duplicate **ACK** if it receives an out of order segment
  - Which leads the sender to assume that there are problems in the network



Source: Simon S. Lam

Security and services

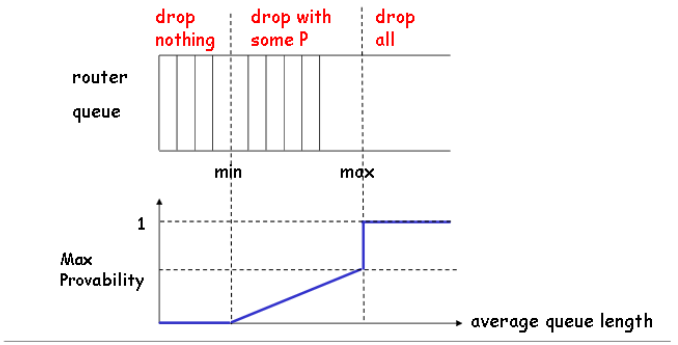
- After 3 double **ACK** **cwnd** is adjusted to **50%** of the current value and the **slow start** process is resumed although with a linear increase of **cwnd**
- But if an **RTO** occurs, **cwnd** is set to the **SMSS** value and the **slow start** process is resumed as initially

- The **slow start** mode can be interpreted as a variation of the **sliding window** with the benefit of allowing an adjustment of the window dimension taking into account the sender, the receiver and the network conditions

Security and services

- Congestion control can take advantage of more mechanisms
- The usual characteristic of the communication asset processing queues is that they are large; unfortunately it can imply high latency and lead TCP to assume that there is congestion and revert to the **slow start** mechanism
- When a device's processing queue is full, the next incoming packets are discarded - a process known as ***tail-drop*** - which represents an important weight in communications
- The ***Random Early Detection*** (**RED**) algorithm can be applied to the crossed nodes to avoid **tail-drop**

Security and services



Source: Jin Hyin Ju

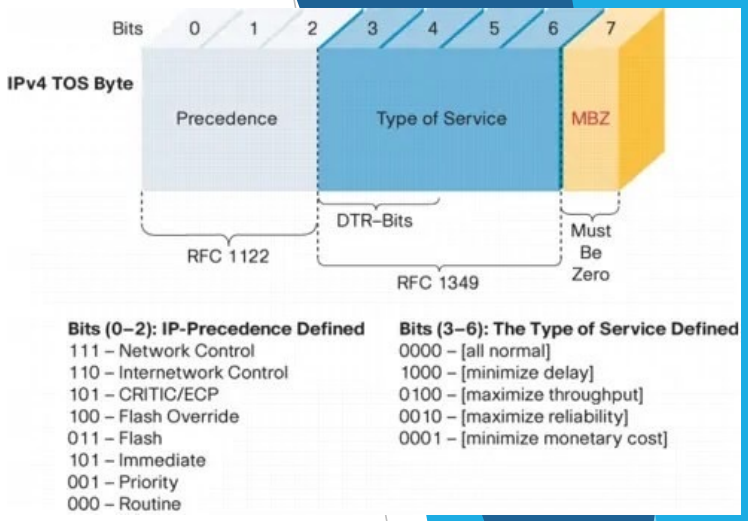
- **RED** maintains two values that define
  - The occupancy of the queue (**Min**$_{th}$) from which it discards new packages with increasing probability p
  - The occupancy of the queue (**Max**$_{th}$) from which all new packages are discarded

Security and services

- The IP header contains fields that differentiate traffic
  - In IPv4 the 8-bit field ***Type of Service*** (**TOS**)
  - In IPv6 the 8-bit field ***Traffic Class*** (**TC**)
- These fields allow to define the priority of the traffic so that the intermediate nodes can treat it differently
- In older devices these fields used only the 3 most significant bits representing the ***IP Precedence***
  - Thus defining 8 (eight) distinct classifications

Security and services

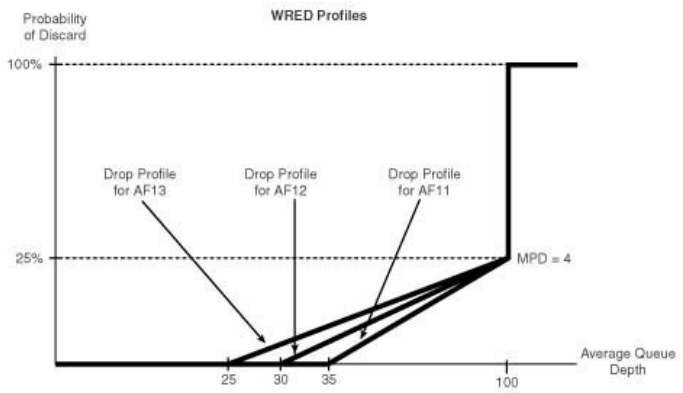
- Subsequently, all bits started to be used under the name ***Differentiated Service*** (**DS**) also known as ***DiffServ***
- The 6 (six) most significant bits are called ***Differentiated Service Code Point*** (**DSCP**) while the 2 (two) least significant bits are called ***Explicit Congestion Notification*** (**ECN**)
- The **DSCP** includes **IP Precedence**, which allows compatibility with old nodes that may still exist on the route
- If any crossed device does not support **DS**, the **DSCP** is ignored on that device but remains on the others



Source: Cisco

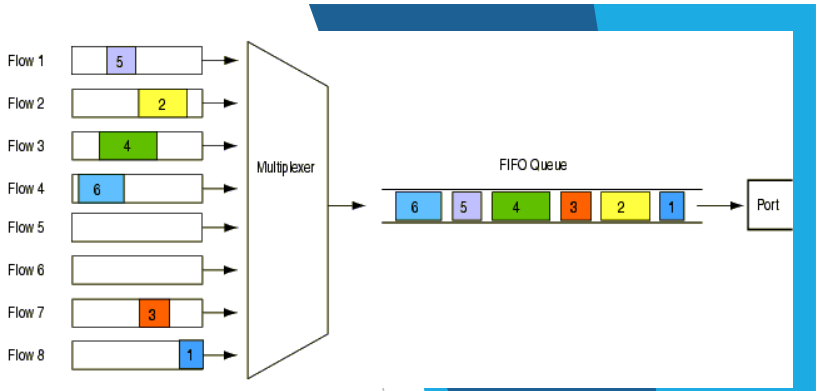
Security and services

- **RED** has the drawback of dropping packets randomly
- Alternatively, you can use the ***Weight Random Early Detection*** (**WRED**) which operates according to the same principle but defining traffic type priorities and a different limit for each priority from which it discards packages according to the occupation of its processing queue
- As seen in the figure, any package has a probability of being discarded but from different queue occupancy percentages
- And, ultimately, all packets will be dropped when the queue is completely full display



Source: Cisco

Security and services

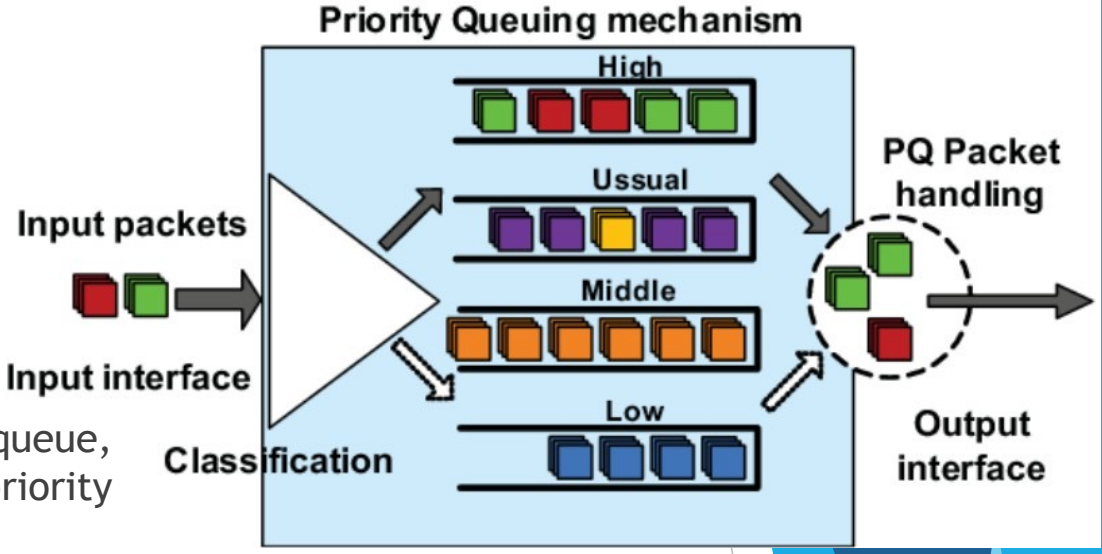


Source: Softwareopal

- Based on the **DSCP** it is possible to segment the packages according to their importance, thus avoiding the default FIFO behavior
- However, the devices traversed by packets by default treat all traffic equally received, so to take advantage of **DCSP** you must configure them for ***Quality of Service*** (**QoS**)
- **QoS** has two methods, ***Soft QoS*** and ***Hard QoS***, both creating distinct and parallel queues for placing traffic according to their classification
  - **Soft QoS** shares resources according to traffic types and does not reserve part of the capacity exclusively for any
  - **Hard QoS** reserves resources statically for defined types of traffic

Security and services

- **Soft QoS** - ***Priority Queuing*** **(PQ)**
- Whenever there is traffic in a higher priority queue, it is always processed before the next lower priority traffic is processed
- This implies that lower priority traffic may never be processed at the limit
- The number of queues is defined in the asset configuration and changing the queues normally implies restarting the asset



Source: ResearchGate

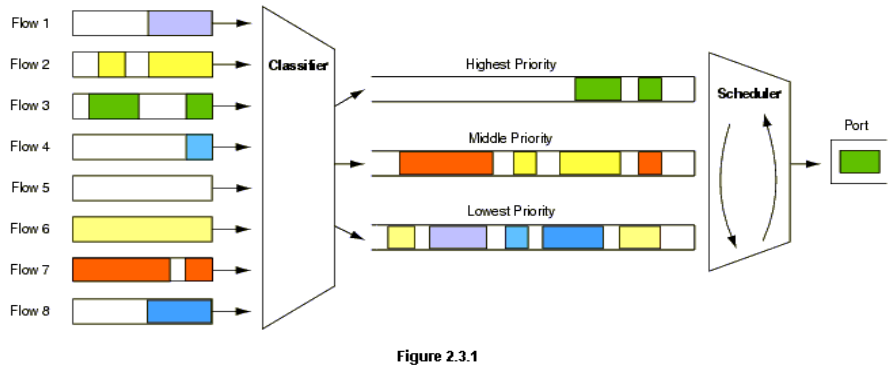
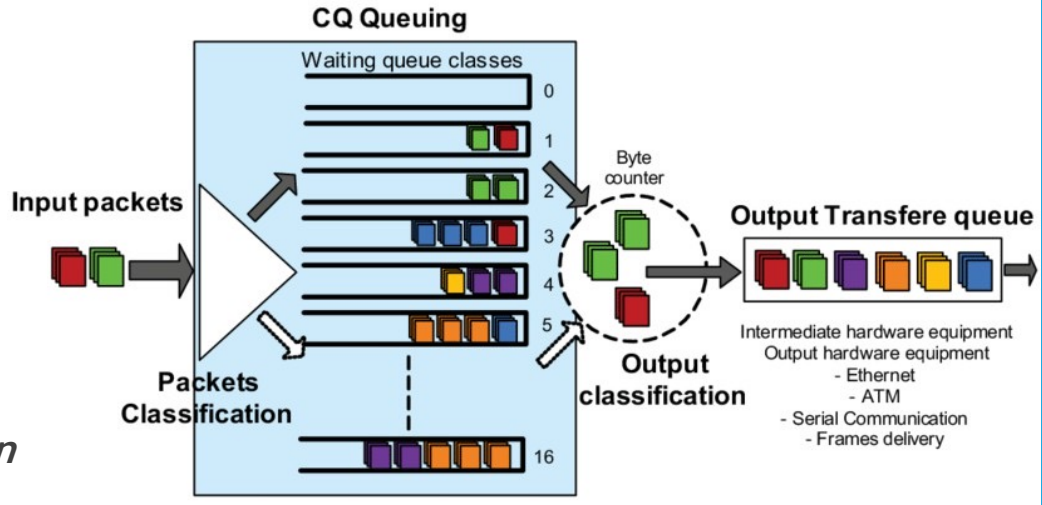


Figure 2.3.1

Source: Softwareopal

Security and services

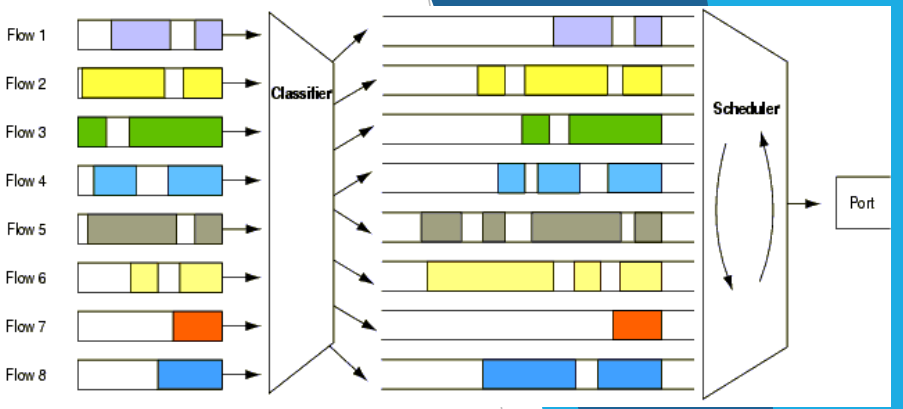
- **Soft QoS** - ***Custom Queuing*** **(CQ)**
- Process packets from each queue in a ***round-robin*** system
- All queues are traversed, processing packets in each of them until the number of bytes that has been defined is exceeded
- **QC** allows for a more reasonable distribution of output capacity, still prioritizing the most priority traffic but without implying the lack of processing of the least priority



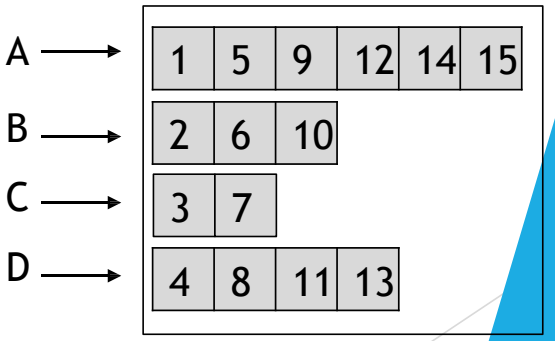
Source: ResearchGate

Security and services

- **Soft QoS** - ***Fair Queuing*** **(FQ)**
- Process packets from each queue in a ***round-robin*** system
- The number of queues created is dynamic, dividing the channel capacity evenly by the different types of traffic being processed
- If the number of traffic types changes, the number of queues changes automatically
- The **FQ** adapts dynamically to different flows
- Each queue process one packet at a time
- Assuming that at any given moment there are **4** queues **A** to **D** and different traffic flows in each one, we will have



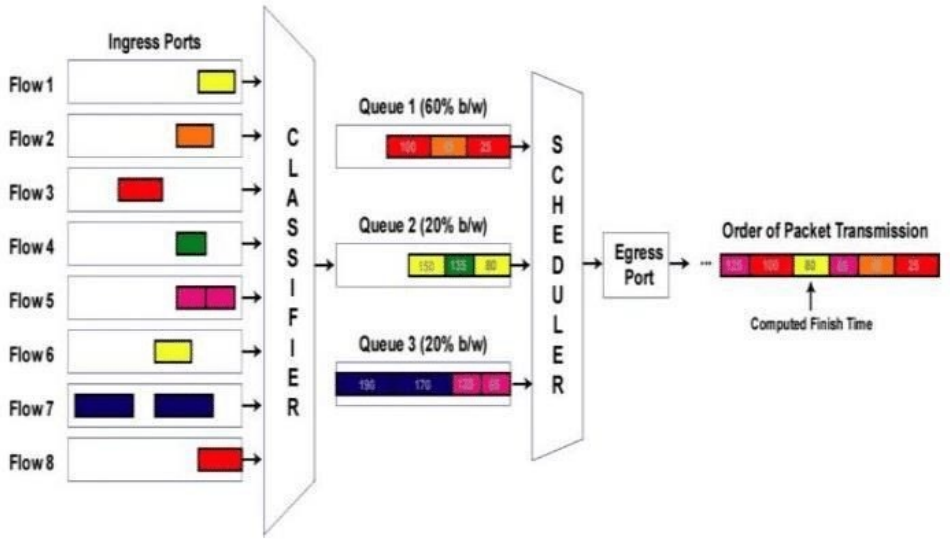
Source: helisetalem.com



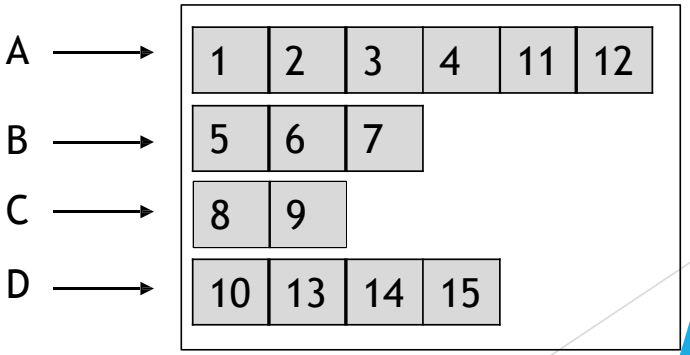
Fila	Tempo final
A	15
B	10
C	7
D	13

Security and services

- **Soft QoS** - ***Weight Fair Queuing*** **(WFQ)**
- Similar to **FQ** but each queue is given a priority
- Output channel capacity is not evenly distributed across existing queues, but as the heavy average of the queues
- Assuming that at a given moment there are **4** queues created with weights **A = 4, B = 3, C = 2, D = 1** and different traffic flows for each of them, we will have



Source: ResearchGate



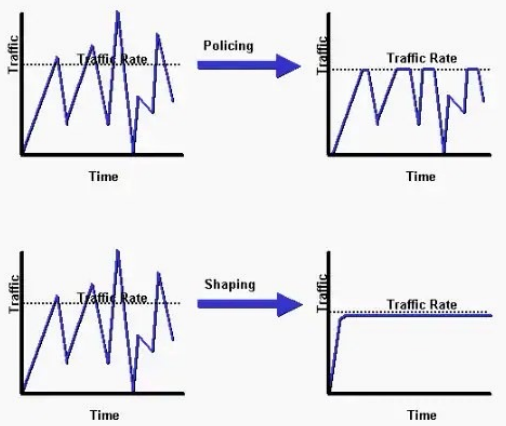
Queue	End time
A	12
B	7
C	9
D	15

Security and services

- **Hard QoS** reserves resources statically for types of traffic
- Its main disadvantage is the failure to use the configured reserves if there is no traffic of this type, which implies a waste of resources.
  - For example, if we reserve 70% of the capacity for HTTP traffic, even if that type of traffic does not exist at any given time, the other types will only have 30% available
- In contrast, the traffic for which resources have been reserved does not suffer any delays due to other types of traffic
- In case of excessive traffic, the allocated bandwidth for a given traffic can always be exhausted
- To minimize the impact of this situation, it uses two complementary concepts that can be used simultaneously
  - *Traffic Policing*
  - *Traffic Shaping*

Security and services

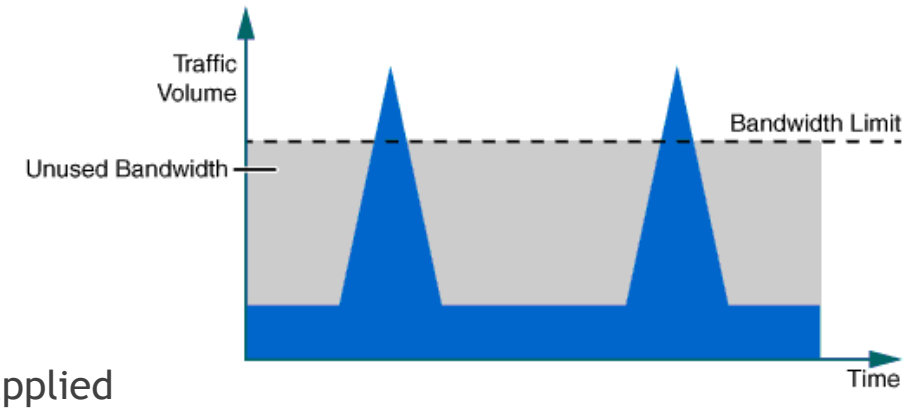
- *Traffic Policing* consists of the pure and simple elimination of traffic that exceeds the capacity assigned to it
- *Traffic Shaping* consists of retaining traffic that exceeds the capacity assigned to it, and retransmitting it when the channel is freer
- The retransmission is scheduled after a certain time has elapsed, repeating the process until successful transmission
- However, it applies in the same way that if the capacity to retain traffic exceeds available resources, new excess traffic will be discarded



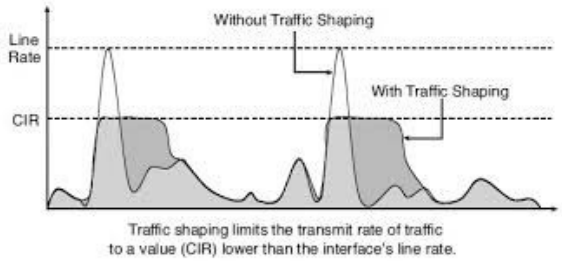
Source: Cisco

Security and services

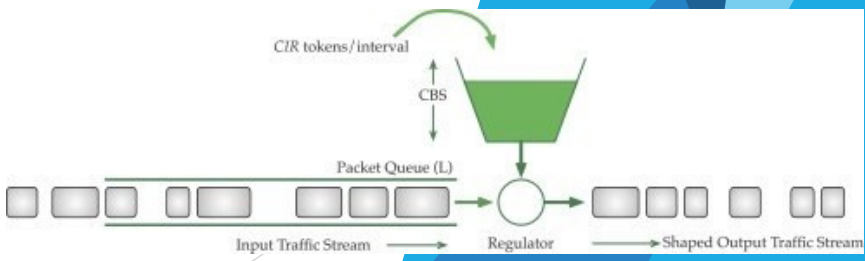
- The traffic that passes through the asset where **QoS** is applied will not, on average, have a constant occupation, with moments of high traffic and others of low traffic
- It is thus possible to estimate an average occupation and, based on it, excess occupation
- Using ***Traffic Shaping*** the number of packages that would potentially be dropped is minimized
  - However, the bowl in the figure below can fill…



Source: Juniper.net



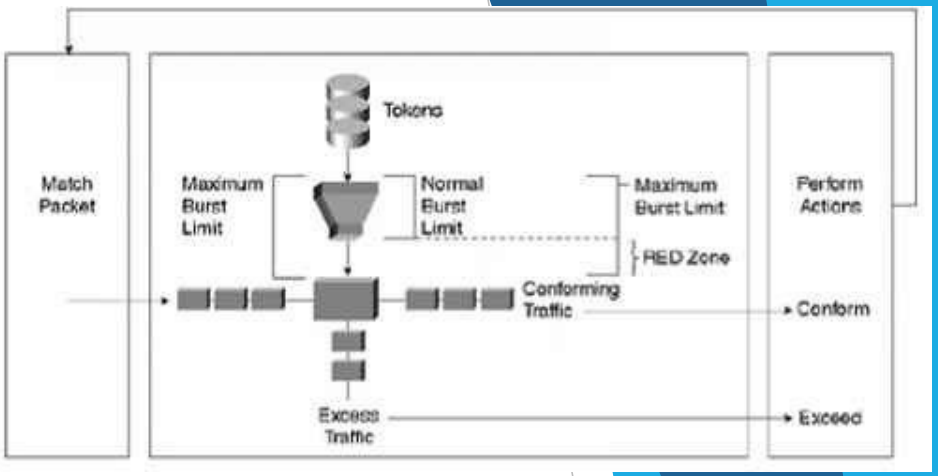
Source: Tutorzine.com



Source: Ronald. J.Vetter

Security and services

- The application of *Traffic Policing* and *Traffic Shaping* techniques are dependent on the brands of the assets
  - For example, *Committed Access Rate* (**CAR**) and *Token Bucket*, in *Traffic Policing*
  - *Leaky Bucket* and *Token Bucket* in *Traffic Shaping*
- The application of *Traffic Shaping* implies the real-time alteration of the *DiffServ* field of the packet



Source: Cisco

Security and services

- Global traffic can be divided between *traditional* (for ordinary applications) or *real-time* (*streaming*))
- The traditional can usually suffer delays and losses without significant loss
  - Provided, of course, that it has no consequences on the **SLA**
- But real-time applications are less tolerant of delays, variations (*jitter*) and losses
- For these applications, ***Hard QoS*** that includes ***Traffic Policing*** and ***Traffic Shaping*** mechanisms may not be appropriate

Security and services

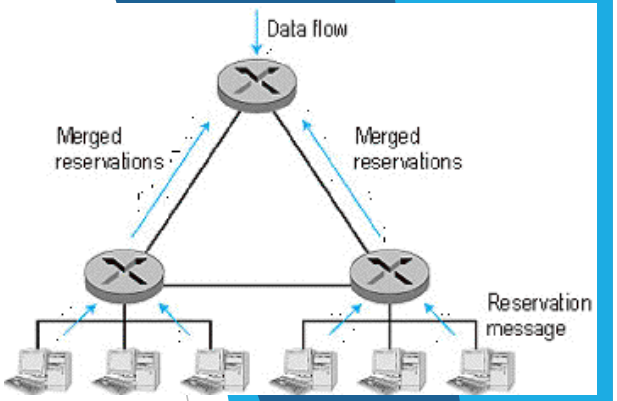
- Hence a different ***Hard QoS*** approach to ***DiffServ*** (and sometimes considered the opposite): ***Integrated Services*** (**IntServ**), driven by real-time application needs
- ***IntServ*** is *multicast* oriented and focuses on resource reservation and packet access control mechanisms along the channel that connects the sender and the receiver
- While *DiffServ* ensures better QoS scalability, *IntServ* provides a more restricted mechanism for real time

Security and services

- *IntServ* needs several functions across devices traversed by packets
  - Admission control to determine whether a new flow can ensure the desired QoS without affecting existing reservations
  - Classification to recognize packets that require specific levels of QoS
  - Policies to act (including discarding packages) when non-compliance with the specified characteristics
  - Queuing and scheduling to handle packages according to desired priorities
- A protocol that uses this approach is the ***Resource ReSerVation Protocol*** (**RSVP**)

Security and services

- **RSVP** is a receiver-oriented protocol
- It is the destination node that contacts the nodes along the route to request the necessary resource reservation
- **RSVP** is not a routing protocol, querying and taking advantage of routing tables along the route to obtain the necessary routes, whether *unicast* or *multicast*
- It works in *simplex* mode, that is, the reservations are guaranteed for only one direction of the flow
- An **RSVP** reservation request can have two types, called *styles*
  - *Distinct* where a reservation is requested for exclusive traffic
  - *Shared* where different flows (including sender and receiver) share the same reserve



Source: ipsit.bu.edu

Security and services

- Reservations may need to be changed, for example because the routing table is changed or more traffic requires reservation
- Each reservation has a life time after which it must be renewed
  - By default, the lifetime of reservations is 30 sec.
  - This time can be changed but bearing in mind that if lower values will optimize the network adaptation, they will also increase the *overhead* inherent to RSVP
- Nodes along the route may or may not support RSVP
  - If they do not support, they ignore the reservation requests and forward them to the next node
  - If they support, process them, forward them to the next node and inform the issuer of the reservation request
- Nodes that support RSVP can aggregate incoming requests that are compatible
  - Therefore, the guarantee of the requested reservation is always partial